Политика за HotelChain Sofia AD

Фирма	HotelChain Sofia AD
Тема и префикс на кодовете	Резервни копия и възстановаване (ВКР)
Версия	0.1
Дата	28.10.2026
Автор	Виктория Ганчева
Одобрил	Управител
Следващ преглед	28.10.2027

1. Цел

Да има копие на резервационната база, така че при ransomware хотелите да могат да възстановяват резервациите. Политиката е насочена към риск R-01 (оценка 20) от регистъра на риска.

Адресирани рискове (R-ID)	R-01 - Ransomware криптира резервационната база (A-01); риск 20; апетит над 9

2. Обхват

Политиката важи за	Reservation DB (A-01), данните за резервации и гости (A-02), виртуалния сървър srv (A-12) и администраторите, които работят с тях.
Извън обхвата	Wi-Fi за гости (A-05) и публичният информационен портал (A-04) не влизат в тази политика.

3. Роли и отговорности

Роля (длъжност)	Отговорност
Администратор бази данни	настройва архивирането на A-01 и 02, проверява резултатите и прави тестове за взстановяване.
Ръководител резервации	Отговаря за риска R-01 и одобрява политиката и изключенията.
Ръководител ИТ	Проверява отчетите, правата за достъп и резултатите от тестовете. Не изпълнява сам архивирането.

4. Контроли

Контрол 1

Код	ВКР-01
Контрол	Ежедневен backup

Изискване	Всеки ден в 02:00 часа се създава копие на Reservation DB (A-01) с данните на гостите (A-02). Последното успешно копие не трябва да е по-старо от 24 часа.
Отговорник	Администратор бази данни - настройва задачата и проверява дали се е изпълнила до край.
Честота	Всеки ден; Проверка до 09:00 часа всяка сутрин.
Проверка	Има успешен Backup за последните 24 часа. Цел: 100% успешни изпълнения за месеца.
Доказателство	Логове на backup задачата и месечен отчет. Пазят се до 90 дни
Annex A	*попълва се в Час 6*
R-ID	R-01

Контрол 2

Код	ВКР-02
Контрол	Отделно и защитено копие
Изискване	Копие на A-01 и 02 се пази на отделно хранилище извън сървъра A-12. Файлът е криптиран, а акаунтът на a-12 няма право да го променя или изтрива.
Отговорник	Администратор база данни - настройва хранилището и достъпа до него.
Честота	След всеки backup; проверка на правата веднъж месечно.
Проверка	Проверява се дали копието е налично и се прави опит за изтриване от акаунта A-12. Очакван резултат: Отказан достъп.
Доказателство	Списък със запазените копия и резултат от теста за отказан достъп; 90 дни
Annex A	*попълва се в Час 6*
R-ID	R-01

Контрол 3

Код	ВКР-03
Контрол	Известие при грешка
Изискване	При неуспешно копие на A-01 системата изпраща известие до администратора на базите данни до 15 мин. Той започва нов backup до 2 часа и уведомява Ръководителя ИТ.
Отговорник	Администратор бази данни- реагира на сигнала; Ръководител ИТ - проследява случая.
Честота	При всяка грешка; тестово известие веднъж месечно.
Проверка	Пуска се тестова грешка. Проверява се дали сигналът идва до 15 мин. и дали случаят е записан.
Доказателство	Лог от известието и запис за предприетото действие; пазят се 90 дни.
Annex A	*попълва се в Час 6*
R-ID	R-01

Контрол 4

Код	ВКР-04
Контрол	Тест за възстановяване
Изискване	Веднъж месечно се възстановява копие на А-01 в отделна тестова среда; Системата трябва да се възстанов до 4 часа . като загубата на данни да е най-много 24 часа.
Отговорник	Администратор бази данни- извършва теста; Ръководител ИТ- проверява протокола.
Честота	До последния работен ден на всеки месец.
Проверка	отчитат се времето за възстановяване и 5 тестови резервации без реални лични данни. Цел: до 4 часа и 5 от 5 правилни записа.
Доказателство	Протокол от теста с дата, време и реултат; пази се 12 месеца
Annex A	*попълва се в Час 6*
R-ID	R-01

Контрол 5

Код	ВКР-05
Контрол	Срок за пазене и достъп
Изискване	За А-01 и 02 се пазят 7 дневни и 4 седмични копия. Администраторът на database може да създава и възстановява копия, но изтриване на защитено копие се разрешава само от Ръководител ИТ.
Отговорник	Администратор бази данни- поддържа копията; Ръководител ИТ- одобрява изтриването.
Честота	Проверка на броя копия и правата, веднъж месечно.
Проверка	Проверяват се наличните 7 дневни и 4 месечни копия и че няма изтриване без разрешение.
Доказателство	Месечен списък на копията и записи за одобрения за изтриване; 90 дни
Annex A	*попълва се в Час 6*
R-ID	R-01

5. Изключения

Одобрява	Ръководител резервации - след писмена заявка с причини и компенсираща мярка.
Максимален срок	7 календарни дни. След изтичането им изключението се прекратява.
Записват се в	Регистър за изключенията: контрол, причина, начало, край, одобрил и мярка.

6. Мерки при неспазване

Ако Backup липсва или тестът за възстановяване е неуспешен. Администраторът за бази данни уведомява Ръководителя ИТ и Ръководителя резервации до 2 часа. Проблемът се записва и се определя срок за поправко до 1 работен ден.

7. Преглед

Преглежда	Ръководител резервации с Ръководител ИТ
Период	На всеки 12 месеца и до 30 дни след сериозен инцидент или промяна в Reservation DB (A-01)

Самопроверка преди качване в git (чеклист 6.2, т. 1 до 10)

№	Проверка	Да / Не
1	Политиката сочи R-ID от регистъра на риска	Да
2	Обхватът казва и какво НЕ влиза	Да
3	Ролите са длъжности; прилагащият и проверяващият са различни	Да
4	Има поне пет разписани контрола	Да
5	Има конкретни стойности там, където е нужно число	Да
6	Нито една забранена формулировка: редовно, периодично, по подходящ начин, при нужда, своевременно, адекватно	Да
7	Всеки контрол има начин на проверка	Да
8	Всеки контрол посочва какво доказателство остава при работата му.	Да
9	Има механизъм за изключения със срок и одобряващ	Да
10	Има дата на следващ преглед	